

# Last time: Computational security

Two relaxations:

1. Security only against **Probabilistic Polynomial Time** adversaries.
2. Security can fail with a **negligible probability**

# Definition of computational security

- Algorithm  $\Pi = (\text{Gen}, \text{Enc}, \text{Dec})$ :
  - $k \in \mathcal{K}$  secret key,  $m \in \mathcal{M}$ : message,  $c \in \mathcal{C}$ : ciphertext
  - $k = \text{Gen}(\mathbf{1}^n)$
  - $c = \text{Enc}_k(m)$
  - $m = \text{Dec}_k(c)$
- Correctness:  $m = \text{Dec}_k(\text{Enc}_k(m))$

$n$ : security parameter  
usually use  $\lambda$

# Computation indistinguishability against eavesdropper

Experiment  $\text{PrivK}_{A,\Pi}^{\text{eav}}(n)$ :

1. Adversary  $A$  is given input  $1^n$ , and outputs two messages  $m_0, m_1 \in \mathcal{M}$   
s.t.  $|m_0| = |m_1|$
2. A key  $k$  is generated using  $\text{Gen}(1^n)$ , a random bit  $b \in \{0,1\}$  is chosen.  $c = \text{Enc}_k(m_b)$  is given to  $A$ .
3.  $A$  outputs  $b'$
4. Experiment outputs 1 if  $b=b'$ , and 0 otherwise.

# Computational Indistinguishability against eavesdropper

Definition (EAV security): a private-key encryption  $\Pi = (\text{Gen}, \text{Enc}, \text{Dec})$  is **EAV-secure**, if for all **probabilistic polynomial time** adversaries  $A$ , there is a **negligible function**  $\text{negl}$  such that for all  $n$ ,

$$\Pr[\text{PrivK}_{A,\Pi}^{eav}(n) = 1] \leq \frac{1}{2} + \text{negl}(n)$$

# Definition

A PRG is a function  $G : \{0,1\}^n \rightarrow \{0,1\}^{n+s}$

Pseudorandomness: for any PPT algorithm  $D$ , there is a negligible function  $\text{negl}$  such that

$$|\Pr[D(G(k)) = 1] - \Pr[D(r) = 1]| \leq \text{negl}(n)$$

For uniformly random  $k \in \{0,1\}^n$  and  $r \in \{0,1\}^{n+s}$

# Existence of PRG

- We believe that PRGs exist – assumption
- Construction from NP hard problems (e.g., 3-SAT)
  1. One-way function from 3-SAT (additional assumption on worst-case hardness to average-case hardness)
  2. One-way function  $\Leftrightarrow$  PRG

Foundations of Cryptography, Volume 1: Basic Tools (2001), Oded Goldreich

If PRG exists, then  $P \neq NP$

# EAV-security from PRG

Construction:

- $\text{Gen}(1^n)$ : choose uniform  $k \in \{0,1\}^n$  and output it as the key
- $\text{Enc}_k(m)$ : on input a message  $m \in \{0,1\}^{n+s}$ , compute

$$c = G(k) \oplus m$$

- $\text{Dec}_k(c)$ : on input a ciphertext  $c \in \{0,1\}^{n+s}$ , compute

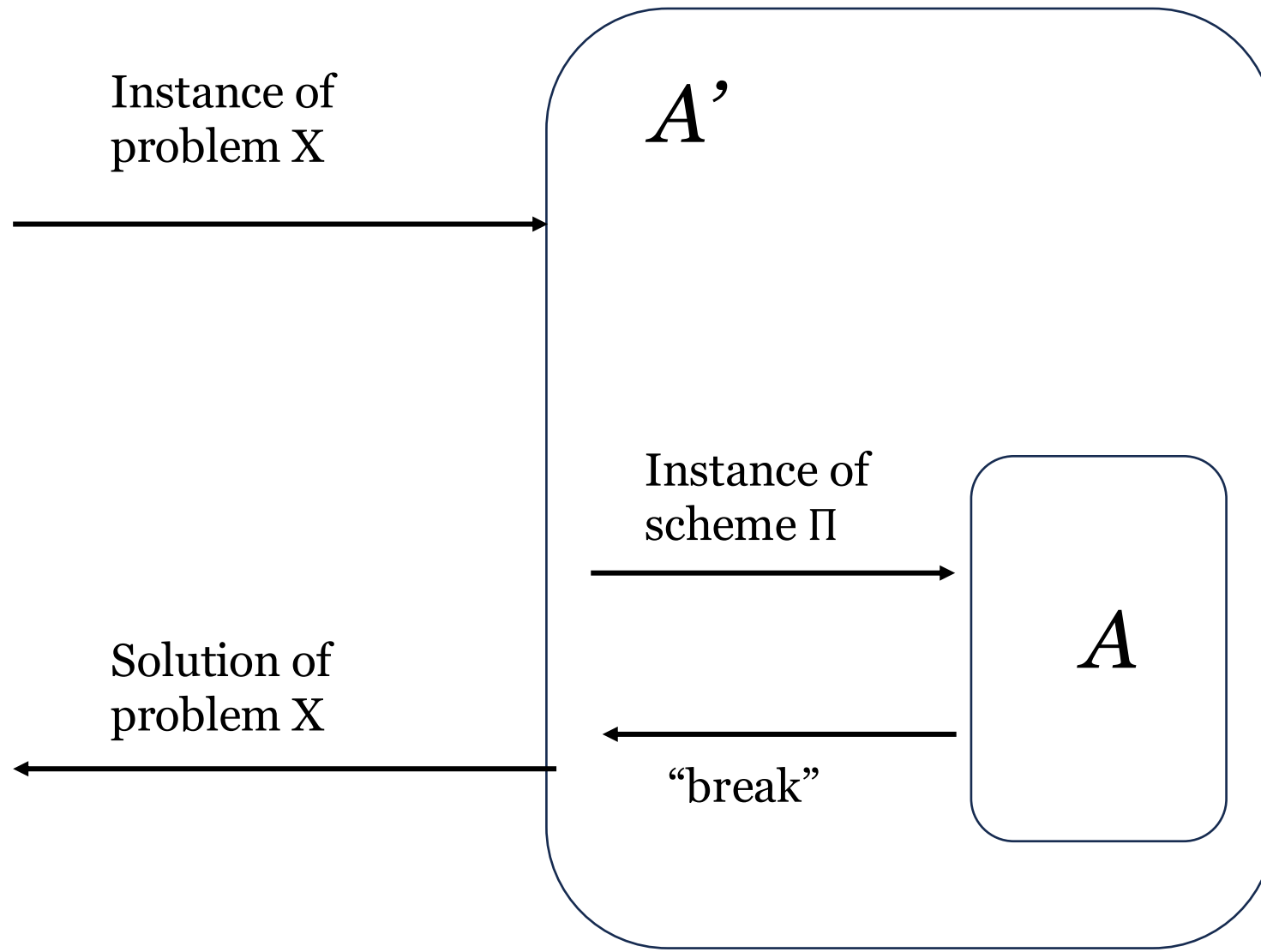
$$m = G(k) \oplus c$$

# EAV-security from PRG

- Theorem: if  $G$  is a PRG, then the construction is EAV secure.
  - Game and Demo;



# Proof by reduction



- $X$  is the hard problem in the assumption
- Polynomial time reduction
- Non-negligible success probability

# Indistinguishability experiment

Experiment  $\text{PrivK}_{A,\Pi}^{\text{eav}}(n)$ :

1. Adversary  $A$  is given input  $1^n$ , and outputs two messages  $m_0, m_1 \in \mathcal{M}$  s.t.  $|m_0| = |m_1|$
2. A key  $k$  is generated using  $\text{Gen}(1^n)$ , a random bit  $b \in \{0,1\}$  is chosen.  $c = \text{Enc}_k(m_b)$  is given to  $A$ .
3.  $A$  outputs  $b'$
4. Experiment outputs 1 if  $b=b'$ , and 0 otherwise.

Definition (EAV security): a private-key encryption  $\Pi = (\text{Gen}, \text{Enc}, \text{Dec})$  is **EAV-secure**, if for all **probabilistic polynomial time** adversaries  $A$ , there is a **negligible function**  $\text{negl}$  such that for all  $n$ ,

$$\Pr[\text{PrivK}_{A,\Pi}^{\text{eav}}(n) = 1] \leq \frac{1}{2} + \text{negl}(n)$$

- Suppose there is  $A$  breaks the EAV security

$$\Pr[\text{PrivK}_{A,\Pi}^{\text{eav}}(n) = 1] > \frac{1}{2} + \text{negl}(n)$$

- Distinguisher  $D$  with input  $1^n$  and a string  $w$  of  $(n+s)$  bits
  1. Run  $A$  to get  $m_0, m_1 \in \mathcal{M}$  s.t.  $|m_0| = |m_1| = n + s$
  2. Choose a random bit  $b \in \{0,1\}$ , set  $c = w \oplus m_b$
  3. Give  $c$  to  $A$  and obtain output  $b'$ . Output 1 if  $b'=b$ , 0 otherwise

If  $w$  is a random string,

$$\Pr[D(w) = 1] = \Pr[\text{PrivK}_{A,\text{OTP}}^{\text{eav}}(n + s) = 1] = \frac{1}{2}$$

If  $w = G(k)$ ,

$$\Pr[D(w) = 1] = \Pr[\text{PrivK}_{A,\Pi}^{\text{eav}}(n) = 1] > \frac{1}{2} + \text{negl}(n)$$

- PRG  $\rightarrow$  EAV secure encryption
  - Key shorter than message, but still one encryption

Common reductions in crypto and TCS

# Semantic security

- Adversary can't infer any information about the message  $m$ .

**THEOREM 3.10** *Let  $\Pi = (\text{Enc}, \text{Dec})$  be a fixed-length private-key encryption scheme for messages of length  $\ell$  that is EAV-secure. Then for all PPT adversaries  $\mathcal{A}$  and  $i \in \{1, \dots, \ell\}$ , there is a negligible function  $\text{negl}$  such that*

$$\Pr [\mathcal{A}(1^n, \text{Enc}_k(m)) = m^i] \leq \frac{1}{2} + \text{negl}(n), \quad (3.2)$$

*where the probability is taken over uniform  $m \in \{0, 1\}^\ell$  and  $k \in \{0, 1\}^n$ , the randomness of  $\mathcal{A}$ , and the randomness of  $\text{Enc}$ .*

# Semantic security

$$\left| \Pr[\mathcal{A}(1^n, \text{Enc}_k(m), h(m)) = f(m)] - \Pr[\mathcal{A}'(1^n, |m|, h(m)) = f(m)] \right|,$$

- EAV-security is equivalent to semantic security.

# Can you encrypt 2 messages now?

Construction:

- $\text{Gen}(1^n)$ : choose uniform  $k \in \{0,1\}^n$  and output it as the key
- $\text{Enc}_k(m)$ : on input a message  $m \in \{0,1\}^{n+s}$ , compute

$$c = G(k) \oplus m$$

- $\text{Dec}_k(c)$ : on input a ciphertext  $c \in \{0,1\}^{n+s}$ , compute

$$m = G(k) \oplus c$$

# Indistinguishability for multiple encryptions

Experiment  $\text{PrivK}_{A,\Pi}(n)$ :

1. Adversary  $A$  is given input  $1^n$ , and outputs two **lists** of messages  $M_0 = \{m_{01}, m_{02}, \dots, m_{0t}\}, M_1 = \{m_{11}, m_{12}, \dots, m_{1t}\}$ , s.t.  $|m_{0i}| = |m_{1i}| \forall i = 1, \dots, t$
2. A key  $k$  is generated using  $\text{Gen}(1^n)$ , a random bit  $b \in \{0,1\}$  is chosen. A list  $C = \{c_1, c_2, \dots, c_t\}$  is given to  $A$ , where  $c_i = \text{Enc}_k(m_{bi}) \forall i = 1, \dots, t$
3.  $A$  outputs  $b'$
4. Experiment outputs 1 if  $b=b'$ , and 0 otherwise.

Definition: a private-key encryption  $\Pi = (\text{Gen}, \text{Enc}, \text{Dec})$  is secure, if for all probabilistic polynomial time adversaries  $A$ , there is a negligible function  $\text{negl}$  such that for all  $n$ ,

$$\Pr[\text{PrivK}_{A,\Pi}(n) = 1] \leq \frac{1}{2} + \text{negl}(n)$$



# Security now?

The construction is not secure under the new definition

$$M_0 = \{\mathbf{0}^{n+s}, \mathbf{0}^{n+s}\}, M_1 = \{\mathbf{0}^{n+s}, \mathbf{1}^{n+s}\},$$

# Necessity of probabilistic encryption

No deterministic encryption can be secure under the definition of multiple encryptions.

# Probabilistic encryption

Encrypting the same message multiple times gives **different** ciphertexts.

$\mathbf{r}, c \leftarrow \text{Enc}_k(\mathbf{r}, m)$ , a random  $\mathbf{r}$  is chosen for every encryption, and sent to the receiver

$m \leftarrow \text{Dec}_k(r, c)$

# Chosen-plaintext attack (CPA) security

Experiment  $\text{PrivK}_{A,\Pi}^{\text{CPA}}(n)$ :

1. A key  $k$  is generated using  $\text{Gen}(1^n)$
2. Adversary  $A$  is given input  $1^n$ , and **oracle access to  $\text{Enc}_k(\cdot)$** .  $A$  outputs two messages  $m_0, m_1 \in \mathcal{M}$  s.t.  $|m_0| = |m_1|$
3. A random bit  $b \in \{0,1\}$  is chosen.  $c = \text{Enc}_k(m_b)$  is given to  $A$ .
4.  $A$  continues to have **oracle access to  $\text{Enc}_k(\cdot)$**  and outputs  $b'$
5. Experiment outputs 1 if  $b=b'$ , and 0 otherwise.

Definition: a private-key encryption  $\Pi = (\text{Gen}, \text{Enc}, \text{Dec})$  is CPA-secure, if for all probabilistic polynomial time adversaries  $A$ , there is a negligible function  $\text{negl}$  such that for all  $n$ ,

$$\Pr[\text{PrivK}_{A,\Pi}^{\text{CPA}}(n) = 1] \leq \frac{1}{2} + \text{negl}(n)$$

# What about multiple encryptions now?

- **Theorem:** any private-key encryption scheme that is CPA-secure, is also CPA-secure for **multiple** encryptions.

# Stream cipher with Initialization Vector (IV)

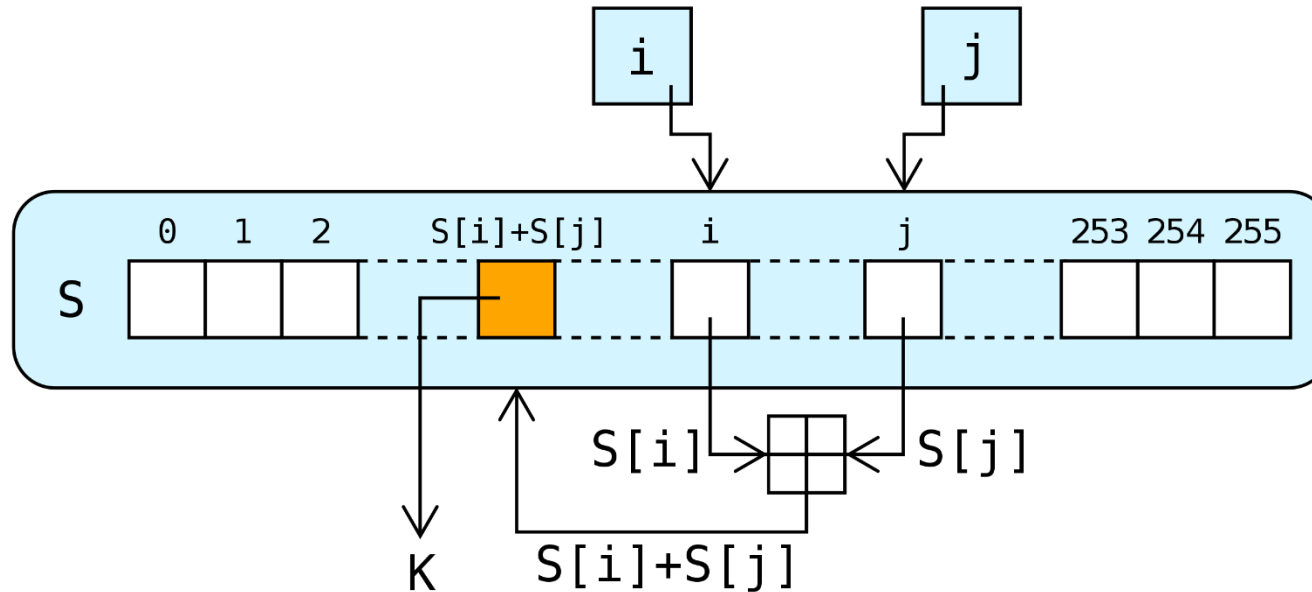
- PRG with IV:  $G(k, IV)$
- $\text{Enc}_k(m)$ : on input a message  $m \in \{0,1\}^{n+s}$ , sample  $IV \in \{0,1\}^n$ , compute

$$c = (IV, G(k, IV) \oplus m)$$

- $\text{Dec}_k(c)$ : on input a ciphertext  $c$ , compute

$$m = G(k, IV) \oplus c$$

# RC4 (Ron Rivest 1987)



Key scheduling

```
for i from 0 to 255
  S[i] := i
endfor
j := 0
for i from 0 to 255
  j := (j + S[i] + key[i mod keylength]) mod 256
  swap values of S[i] and S[j]
endfor
```

PRG

```
i := 0
j := 0
while GeneratingOutput:
  i := (i + 1) mod 256
  j := (j + S[i]) mod 256
  swap values of S[i] and S[j]
  K := S[(S[i] + S[j]) mod 256]
  output K
endwhile
```

# Vulnerability of RC4

- Output not uniform
- Handling IV is not secure
- Replacement: ChaCha20

See more in textbook Chapter 7.1\*